

SECURITY VULNERABILITY DETECTION USING AI TECHNOLOGY ON WEB APPLICATION SYSTEMS

MSc Dissertation Research Presentation

Summary of research methodology,
implementation, evaluation and findings

THE RESEARCH AIMS AND OBJECTIVES

The research main aim is:

This research seeks to investigate and develop enhanced models for detecting vulnerabilities such as SQL Injection (SQLi) and Cross-site Scripting (XSS) threats that exploit web application systems, especially PHP-based ones.

To obtain the primary aim of this study the following objectives should be achieved:

- To evaluate the performance of Support Vector Machine (SVM), Logistic Regression (LR), Random Forest (RF), Gradient Boosting (GB), Multilayer Perceptron of Neural Networks (MLP,) and Extra Trees (ET) in terms of accuracy, precision, recall and F1-Score for classifying SQLi and XSS vulnerabilities.
- To develop a novel hybrid Stacked Ensemble model, Stacker6X that leverages the strengths of SVM, LR, RF, GB, MLP and ET models for robust web vulnerability detection and evaluate its effectiveness in detecting SQLi and XSS.
- To compare the performance of LR, RF, GB, MLP, and ET with Ensemble Stacker6X model based on accuracy, precision, recall and F1-score in classifying SQLi, XSS and normal payloads.
- To investigate the impact of base models LR, RF, GB, MLP and ET on the accuracy of meta-model trained with the pre-trained SVM model in Stacker6X.
- To investigate the impact of input-feature preprocessing, including special characters, keywords, tokens and hyperparameter tuning on the detection capabilities of the models.
- To investigate the potential of ARIMA model for predicting anomalies for web vulnerabilities detection using simulated timestamp
- To implement Stacker6X using object-oriented programming (OOP) for reusability and deployment in a simulated environment

RESEARCH METHODOLOGY

This section outlines how the research aim and objectives were utilized to guide the investigation and development of models, ensuring they effectively address the requirements for detecting SQLi and XSS vulnerabilities.

The research methodology used is a positivist ideology that utilizes a deductive research approach; It emphasizes the application of empirical and measurable data, focusing on objective analysis where models are tested under controlled conditions and conclusions are drawn from quantitative findings.

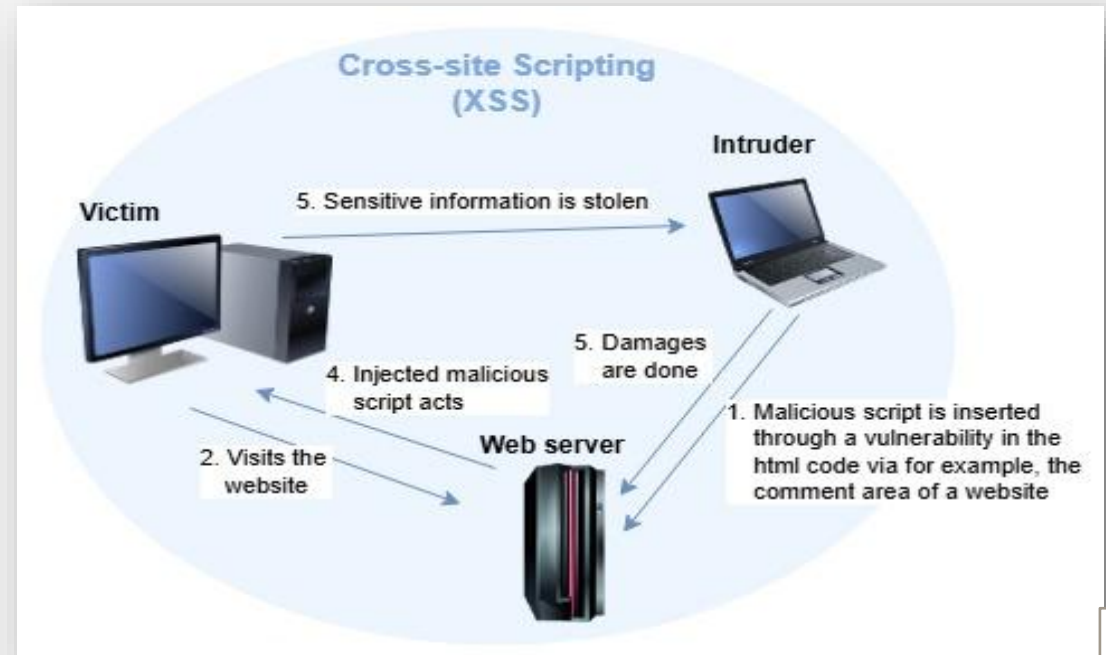
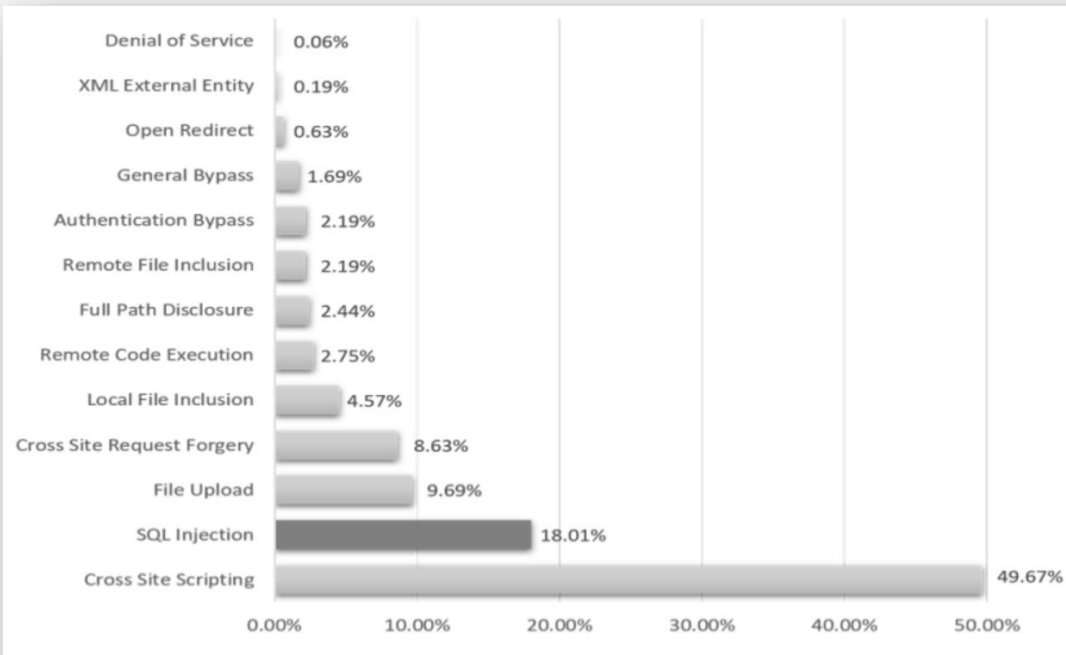
It begins with a hypothesis/theoretical framework (e.g., ML-based web vulnerability detection), followed by experimentation and analysis to validate or refute the hypothesis.

The processes involves evaluating SVM, RF, LR, GB, ET, MLP, ARIMA and a novelty hybrid ensembled model, Stracker6X to test their detection accuracy.



SQL INJECTION AND CROSS-SITE SCRIPTING (XSS)

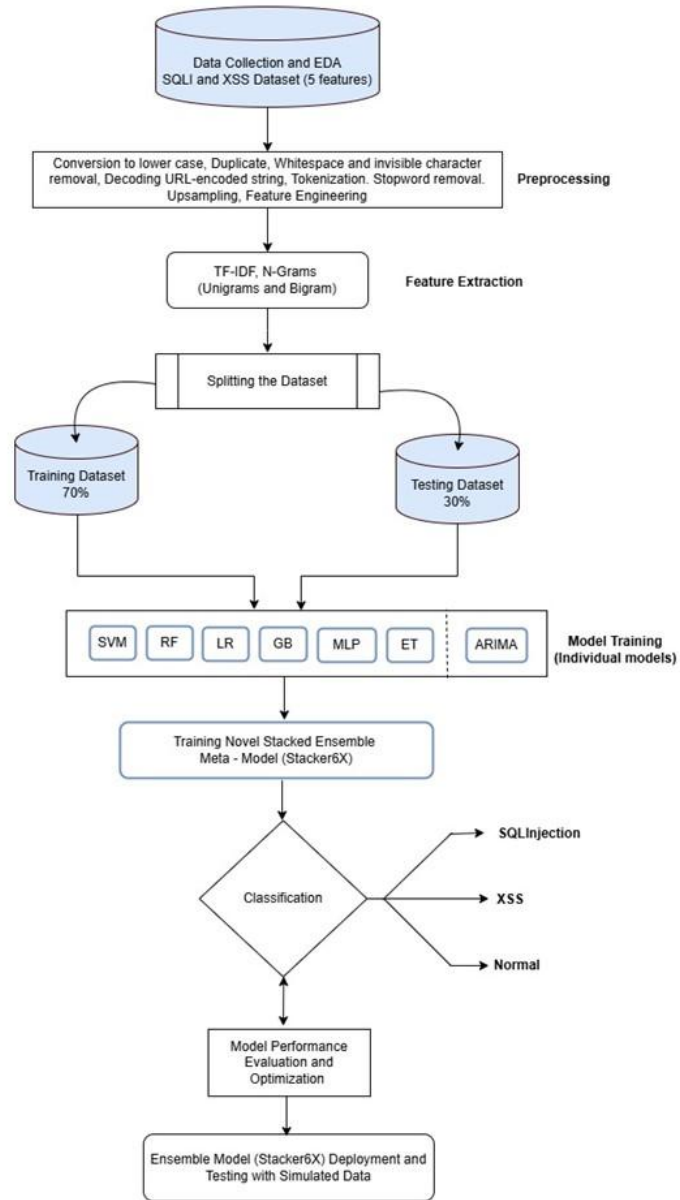
SQLi and XSS are vulnerabilities that affect web application systems, including PHP-based ones. SQLi functions by manipulating data out of a system's or application's database while XSS deceives browsers into inputting malicious client-side scripts to the targeted user's browser that can usually automatically execute when received.



WEB APPLICATION VULNERABILITIES DETECTION TECHNIQUES

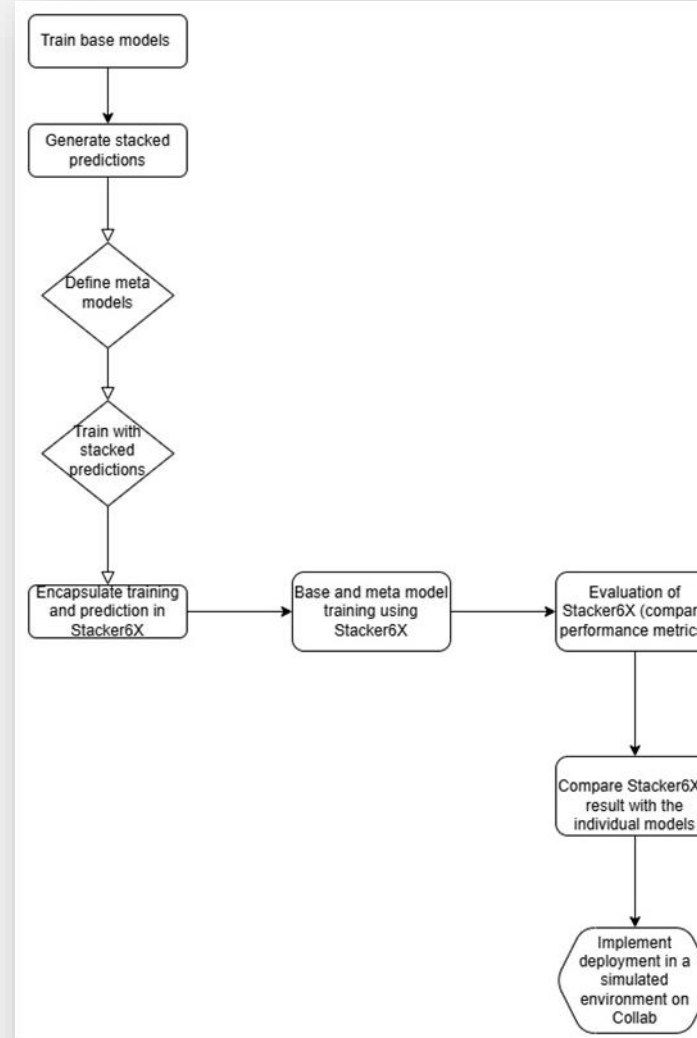
- ❖ Static Application Security Testing (SAST) - uses static analysis techniques to detect software vulnerabilities without running the code. This causes a failure in detecting some vulnerabilities like SQLi that can only be obvious during runtime and consequently affecting the accuracy.
- ❖ Dynamic Application Security Testing (DAST) - DAST tools like OWASP ZAP and Burp Suite are more effective during runtime analysis and simulating real-world simulation.
- ❖ Penetration Testing - helps identify vulnerabilities and weaknesses by simulating real-world friendly attacks so they can be addressed effectively.
- ❖ Machine Learning Based Detection – Based on several studies, ML has been found to be more effective for vulnerability detection of PHP-based web applications because Machine learning can bridge DAST, SAST, and penetration testing by automating processes, improving threat detection accuracy, and reducing manual effort.

Supervised learning methods such as SVM, RF, LR, Extra Trees (ET), Multi-Layer Perceptron (MLP) and GB are used as they leverage labeled data to train models for accurate predictions and classifications. Unsupervised ARIMA method is also tested to investigate its effectiveness based on the available dataset.



All models

THE PROPOSED FRAMEWORK



Novel Hybrid Stacked Ensemble Model, Stacker6X

Proposed framework
for vulnerability
detection
Implementation using
SVM, RF, LR, GB, MLP,
ET,
ARIMA and the novel
ensemble Stacker6X

DATA ANALYSIS AND RESULTS

Table 1: Summary of Dataset Information

No. of Instances	No of Features	Features	SQLInjections	XSS	Normal
206,636	5	Payloads, SQLI, XSS, Normal and	57316	40,799	58,5211

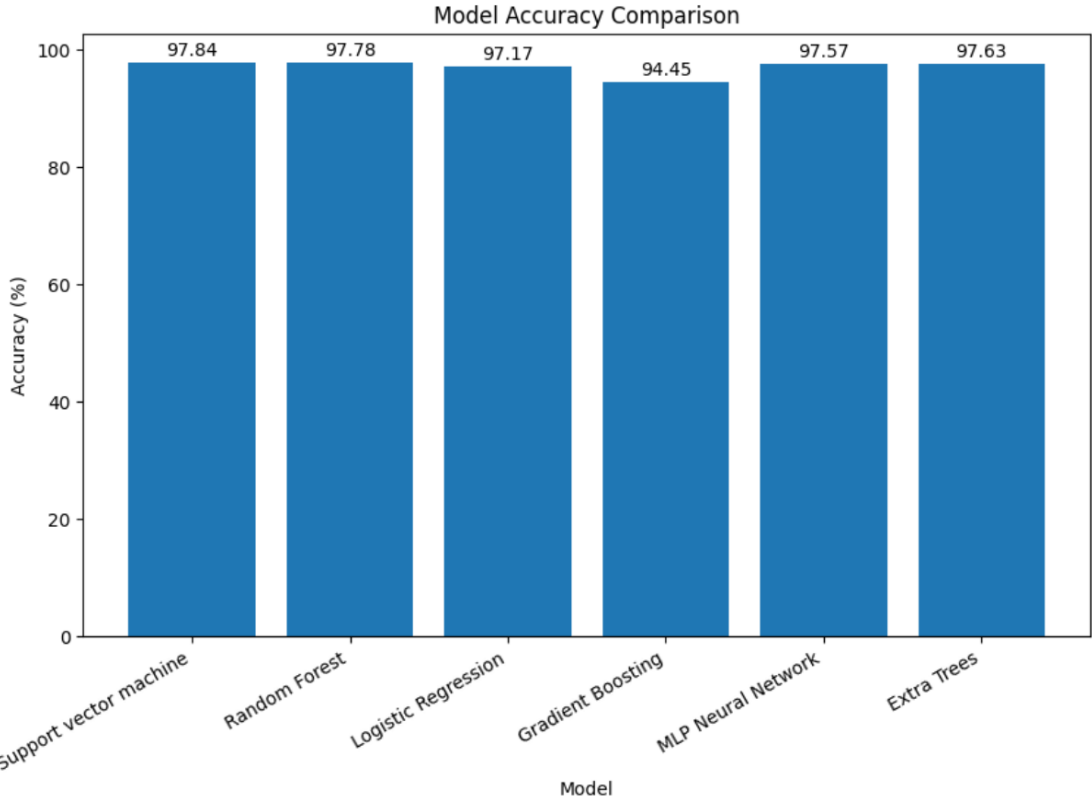
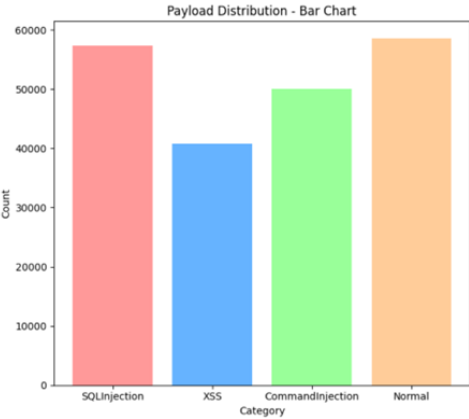
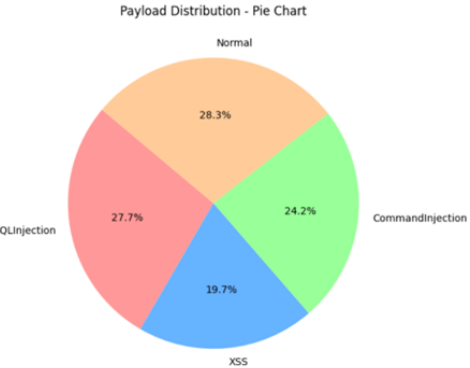


Table 3: Proposed models experimental results

Model	Accuracy (%)	Precision (%)	Recall (%)	F1-Score (%)	SQLi				XSS				Normal			
					TP	TN	FP	FN	TP	TN	FP	FN	TP	TN	FP	FN
SVM	97.84	98.00	98.00	98.00	95.00	99.00	1.00	5.00	100.00	100.00	0.00	0.00	99.00	98.00	2.00	1.00
RF	97.78	98.00	98.00	98.00	97.00	99.00	1.00	3.00	100.00	100.00	0.00	0.00	97.00	98.00	2.00	3.00
LR	97.17	97.00	97.00	97.00	93.00	99.00	1.00	7.00	100.00	100.00	0.00	0.00	99.00	96.00	4.00	1.00
GB	94.45	95.00	94.00	94.00	85.00	99.00	1.00	15.00	99.00	100.00	0.00	1.00	99.00	92.00	8.00	1.00
MLP	97.57	97.00	97.00	97.00	95.00	99.00	1.00	5.00	100.00	100.00	0.00	0.00	97.00	98.00	2.00	3.00
ET	97.63	97.00	97.00	97.00	95.00	99.00	1.00	5.00	100.00	100.00	0.00	0.00	98.00	97.00	3.00	2.00
Ensemble model (Stacker6X)	97.72	98.00	98.00	98.00	95.00	99.00	1.00	5.00	100.00	100.00	0.00	0.00	98.00	98.00	2.00	2.00

6. EVALUATION AND RECOMMENDATION

The summary of research findings and evaluation of objectives of the research.

Based on the evaluations done using performance metrics such as accuracy, precision, recall, F1-score and confusion matrix, the objective to determine the effectiveness AI and ML based models for web vulnerability detection such as SQLi and XSS was established.

The objective to develop a novel Hybrid Stacked Ensemble model, Stacker6X that leverages on the individual strengths of models to give better performances was achieved.

The absence of adequate temporal data limited the ability to use ARIMA for anomaly detection, a step that would have trained the model to first identify anomalies. The objective to determine its effectiveness was also established.

The limitations of this research include the absence of deployment of the model for live processing and analyzing live traffic with payload data and subsequently executing vulnerability detection in real time for actual proactive security.

it is recommended that future research should further expand the methods to capture more web vulnerabilities while improving on its capacity for real time tracking



REFERENCES

- ❖ Hasan, M., Balbahaith, Z. and Tarique, M. (2019) 'Detection of SQL Injection Attacks: A Machine Learning Approach', *2019 International Conference on Electrical and Computing Technologies and Applications, ICECTA 2019* [Preprint]. Available at: <https://doi.org/10.1109/ICECTA48151.2019.8959617>.